

Document title	Customer Security Questionnaire Response — PharmaVital a.s.
Document ID	SLP-ISMS-015
Version	1.0
Classification	Internal
Owner	ISMS Manager
Approved by	Peter Kováč, Managing Director
Date	18 June 2026

DISCLAIMER: SLOVPACK s.r.o. is a fictional company created for portfolio purposes. All data, names and scenarios are invented.

Introduction

This document responds to the information security questionnaire received from PharmaVital a.s. on 8 January 2026. Responses reflect the status of SLOVPACK's ISMS implementation as of June 2026. Supporting documents are referenced by ID and available on request.

Responses

Q1. Do you have a management-approved information security management system (ISMS)? To which standard? Yes. SLOVPACK is implementing an ISMS aligned with ISO/IEC 27001:2022. The scope is formally defined (SLP-ISMS-002) and the Information Security Policy is approved by the Managing Director (SLP-ISMS-003). Certification is targeted within 18 months.

Q2. Please attach your information security policy and a list of roles and responsibilities. Provided. The Information Security Policy (SLP-ISMS-003) sets out management commitment and security principles. Roles and responsibilities are defined using a RACI model (SLP-ISMS-004), with the Managing Director accountable and a designated ISMS Manager responsible for day-to-day operation.

Q3. Do you perform regular risk assessments? Please attach your methodology. Yes. A documented risk assessment methodology (SLP-ISMS-005) defines a 1–5 likelihood/impact scale and risk acceptance criteria. Risks are recorded in a risk register of 20 identified risks (SLP-ISMS-007), each mapped to Annex A controls, with a risk treatment plan tracking remediation (SLP-ISMS-008).

Q4. How do you manage access to confidential information (production specifications, contracts)? Do you perform regular access reviews? Access follows least-privilege and need-to-know principles under the Access Control Policy (SLP-ISMS-POL-002). Access to production specifications is restricted to production leads and the Managing Director. Quarterly access reviews are performed for the ERP and Microsoft 365; the Q1 2026 review removed 14 excess permissions, verified during internal audit (SLP-ISMS-011).

Q5. Do you have a security incident management process, including customer notification within 24 hours? Yes. The Incident Management Policy (SLP-ISMS-POL-005) defines event reporting within 1 hour, a defined escalation path, GDPR notification within 72 hours, and notification of affected pharmaceutical customers within 24 hours in line with contractual requirements. Detailed procedures are held in the Cyber Incident Response Plan.

Q6. How do you secure your sub-contractors (IT services, hosting)? Suppliers are classified and governed under the Supplier Security Policy (SLP-ISMS-POL-006). Critical suppliers (managed service provider, e-shop developer, hosting provider) are required to meet contractual security obligations covering confidentiality, incident notification, named privileged accounts with MFA, right to audit and data return on termination. Critical suppliers are assessed annually using a third-party risk questionnaire.

Q7. Do you regularly test the restoration of backups of critical systems? Yes. The Backup Policy (SLP-ISMS-POL-004) requires quarterly restore tests with written reports. The most recent test (May 2026) successfully restored the ERP database to a test environment in under four hours, with results verified by the Finance & HR Manager.

Q8. Do you perform internal security audits? Please attach the latest report. Yes. An internal audit programme (SLP-ISMS-010) schedules audits across the ISMS during 2026. The most recent audit (SLP-ISMS-011) reviewed access control and backup, identified two nonconformities, and confirmed corrective actions, which are tracked to closure in the corrective action register (SLP-ISMS-013).

Q9. Do you plan ISO/IEC 27001 certification? On what horizon? Yes. Certification against ISO/IEC 27001:2022 is planned within 18 months of ISMS implementation. The Statement of Applicability (SLP-ISMS-009) covering all 93 Annex A controls has been issued, and control implementation is progressing on schedule.

Closing statement

SLOVPACK s.r.o. considers information security a core requirement of its relationship with PharmaVital a.s. and welcomes further dialogue, including a supplier audit if required. Point of contact: ISMS Manager.